ClinicShield

Owner summary

Assessment time: 2026-11-08T18:03:25.931811+00:00
Fictional example: southside_counseling
Evidence mode: documented fictional scenario
Demo only. These changes are made-up assumptions. They are not completed corrective actions or verified improvement.

82/100 | Needs attention

Safeguards 70.2/100 | Exposure 100.0/100
Weighting: 60% Safeguards + 40% Exposure. Status: provisional
Safeguards shows how your answers scored. Exposure starts at 100 and drops for confirmed technical findings. A higher score does not prove that your systems are safe. Provisional means there are gaps or checks still open.

Read the score with its limits

8 coverage issues | 30 finding groups need review.
Missing evidence is not proof of safety. Scores use only the data supplied. Draft mappings may still need review. This prototype does not prove that a clinic is safe, meets health care law or is ready for live use.
- Some source or inventory coverage is unassessed.
- Some findings require verification.
- Some applied rule definitions remain drafts.

Fix First: highest-ranked actions

Priority is finding points divided by effort. It does not predict a score gain or a drop in real risk. Check costs and the work needed before you start.

#1 | R12 | cloud:4
Check email multifactor authentication (MFA) with the service owner. MFA adds a second proof of identity to a password. Fix confirmed gaps. Check t...
Owner: Email administrator or managed service provider | Effort: 2/3 | Cost: unknown

#2 | R16 | assessment
Check each Q10 safeguard on its own. Fix confirmed gaps in how often backups run. Check that backups are separate from daily work access. If Q11 is...
Owner: IT administrator and backup service provider | Effort: 3/3 | Cost: unknown

#3 | R20 | assessment
Check each safeguard on its own. If Q20 is No, write a plan for a security incident. List roles and contacts. If Q24a is No, name a person in charg...
Owner: Organizational leadership and designated security official | Effort: 3/3 | Cost: unknown

Next: agree owners, confirm evidence and request provider estimates. The appendix contains all actions, evidence, score arithmetic and coverage warnings. Summary labels may be shortened.

Detailed appendix

Full report including findings requiring verification. Unsupported glyphs are shown as [U+code].

ClinicShield assessment
Fictional clinic: southside_counseling
Evidence mode: documented fictional scenario
Demonstration only; not an assessment of a real clinic. Any scenario evidence is synthetic, and its timestamps represent fixture generation rather than real-world verification. Live threat-intelligence caches are not loaded.

Assessment time: 2026-11-08T18:03:25.931811+00:00

Overall score: 82/100 - Needs attention
Score status: provisional
Safeguards score: 70.2/100
Exposure score: 100.0/100
Overall weighting: 60% Safeguards and 40% Exposure.

How to read this report

Safeguards shows how your answers scored. Exposure starts at 100 and drops for confirmed technical findings. A higher score does not prove that your systems are safe. Provisional means there are gaps or checks still open.
Missing evidence is not proof of safety. Scores use only the data supplied. Draft mappings may still need review. This prototype does not prove that a clinic is safe, meets health care law or is ready for live use.

Word guide

IT / NA / VPN / SMB / BAA: Information technology / not applicable / virtual private network / Server Message Block file sharing / Business Associate Agreement. A VPN alone does not prove that access is safe.
Finding: A gap or a check raised by the supplied data. Confirmed means supported by that data, not an on-site check.
Coverage: What the tool could check. Unassessed means it could not check; it does not mean safe.
Entity: A device, cloud service or other item used to group scores. A cap sets the most points one item can lose.
Effort: 1: under an hour and free. 2: a day or a small cost. 3: vendor help, budget or several weeks.
CSV / JSON / XLSX / XML / TXT / PDF: Comma-separated values / JavaScript Object Notation / Excel workbook / Extensible Markup Language / plain text / Portable Document Format. These are file types.
OS / MFA / EHR / PHI: Operating system / multifactor authentication / electronic health record / protected health information. Do not upload patient data.
CVE / NVD / CVSS: Common Vulnerabilities and Exposures: weakness IDs. National Vulnerability Database: public weakness records. Common Vulnerability Scoring System: a source severity score.
CISA / KEV / EPSS: Cybersecurity and Infrastructure Security Agency / Known Exploited Vulnerabilities catalog / Exploit Prediction Scoring System. KEV lists flaws used in attacks. EPSS estimates a flaw's chance of use in attacks over 30 days; it does not prove your systems are affected.
HHS / HICP / CPG: US Department of Health and Human Services / Health Industry Cybersecurity Practices / Cybersecurity Performance Goals. Project links to these sources may be partial or still need review.
NIST / CSF / CIS / HIPAA: National Institute of Standards and Technology / Cybersecurity Framework / Center for Internet Security / Health Insurance Portability and Accountability Act. References do not prove compliance.
TCP / UDP / TLS / SSH / RDP / HTTP / HTTPS: Transmission Control Protocol / User Datagram Protocol / Transport Layer Security / Secure Shell / Remote Desktop Protocol / Hypertext Transfer Protocol / HTTP over TLS. These name network methods or services.

Why this score

Arithmetic explains the assessed scope, not complete coverage or safety. Unknown answers earn zero safeguards weight; review-only technical evidence adds no confirmed Exposure deduction. Administrative findings add no extra Exposure deduction. Grouped risks are counted once. Q24 follow-ups are scored once through Q24, not as separate questions.
Safeguards: 100 x 33 / 47 = 70.2128 (exact 3300/47)
Q01: No; weight 3; earned 0 of 3.
Q02: Yes; weight 3; earned 3 of 3.
Q03: Yes; weight 1; earned 1 of 1.
Q04: Yes; weight 1; earned 1 of 1.
Q05: Unknown; weight 1; earned 0 of 1.

Q06: Yes; weight 3; earned 3 of 3.
Q07: Yes; weight 3; earned 3 of 3.
Q08: Yes; weight 3; earned 3 of 3.
Q09: Yes; weight 1; earned 1 of 1.
Q10: No; weight 3; earned 0 of 3.
Q11: Yes; weight 3; earned 3 of 3.
Q12: No; weight 1; earned 0 of 1.
Q13: Yes; weight 1; earned 1 of 1.
Q14: Yes; weight 1; earned 1 of 1.
Q15: Yes; weight 1; earned 1 of 1.
Q16: Yes; weight 1; earned 1 of 1.
Q17: Yes; weight 3; earned 3 of 3.
Q18: Unknown; weight 1; earned 0 of 1.
Q19: Yes; weight 1; earned 1 of 1.
Q20: No; weight 3; earned 0 of 3.
Q21: Yes; weight 3; earned 3 of 3.
Q22: Yes; weight 1; earned 1 of 1.
Q23: Unknown; weight 1; earned 0 of 1.
Q24: No; weight 1; earned 0 of 1.
Q25: Yes; weight 3; earned 3 of 3.
Exposure: 14 scoring entities; cap 25 points per entity.
cloud:1: 0.0000 (exact 0/1) before cap; 0.0000 (exact 0/1) after cap.
cloud:2: 0.0000 (exact 0/1) before cap; 0.0000 (exact 0/1) after cap.
cloud:3: 0.0000 (exact 0/1) before cap; 0.0000 (exact 0/1) after cap.
cloud:4: 0.0000 (exact 0/1) before cap; 0.0000 (exact 0/1) after cap.
cloud:5: 0.0000 (exact 0/1) before cap; 0.0000 (exact 0/1) after cap.
device:SC-LT01: 0.0000 (exact 0/1) before cap; 0.0000 (exact 0/1) after cap.
device:SC-LT02: 0.0000 (exact 0/1) before cap; 0.0000 (exact 0/1) after cap.
device:SC-LT03: 0.0000 (exact 0/1) before cap; 0.0000 (exact 0/1) after cap.
device:SC-LT04: 0.0000 (exact 0/1) before cap; 0.0000 (exact 0/1) after cap.
device:SC-LT05: 0.0000 (exact 0/1) before cap; 0.0000 (exact 0/1) after cap.
device:SC-LT06: 0.0000 (exact 0/1) before cap; 0.0000 (exact 0/1) after cap.
device:SC-LT07: 0.0000 (exact 0/1) before cap; 0.0000 (exact 0/1) after cap.
device:SC-PH01: 0.0000 (exact 0/1) before cap; 0.0000 (exact 0/1) after cap.
device:SC-PH02: 0.0000 (exact 0/1) before cap; 0.0000 (exact 0/1) after cap.
Capped total 0.0000 (exact 0/1) x size factor 1.0000 (exact 1/1) = adjusted deduction 0.0000 (exact 0/1).
Exposure = max(0, 100 - adjusted deduction) = 100.0000 (exact 100/1).
Combined: 0.6 x Safeguards + 0.4 x Exposure = 82.1277 (exact 3860/47).
Rounded score: 82. Nearest whole number; exact .5 ties round upward.
No confirmed Critical ceiling applied; unresolved evidence still requires review.
Final score: 82/100; Needs attention.

Practice-area results (draft)

These practice views are a draft. They use project groups, not an official Health Industry Cybersecurity Practices (HICP) crosswalk. Safeguards uses your answers. Exposure shows known deductions only. No confirmed technical findings means unassessed, not 100. Both parts are needed for a combined score. All scores are provisional: checks are still open. Practice scores do not add or average into the overall score.

1. Email protection [draft provisional]

Safeguards: 50.00/100 (3/6 weight)
Exposure: unassessed
Combined: unavailable; both components required
Inventory denominator: 14 entities; size factor 1/1; cap 25 points per entity.
Review groups: 0; assessment coverage warnings: 8.
Global coverage warnings remain relevant; no practice-wide completeness is established.
Scores use primary project assignments and independently capped practice views.
A missing component is not replaced or reweighted.

2. Endpoint protection [draft provisional]

Safeguards: 66.67/100 (2/3 weight)
Exposure: unassessed
Combined: unavailable; both components required
Inventory denominator: 14 entities; size factor 1/1; cap 25 points per entity.
Review groups: 2; assessment coverage warnings: 8.
Unknown answers earning zero: Q05
Global coverage warnings remain relevant; no practice-wide completeness is established.
Scores use primary project assignments and independently capped practice views.
A missing component is not replaced or reweighted.

3. Access management [draft provisional]

Safeguards: 100.00/100 (10/10 weight)
Exposure: unassessed
Combined: unavailable; both components required
Inventory denominator: 14 entities; size factor 1/1; cap 25 points per entity.
Review groups: 9; assessment coverage warnings: 8.
Global coverage warnings remain relevant; no practice-wide completeness is established.
Scores use primary project assignments and independently capped practice views.
A missing component is not replaced or reweighted.

4. Data protection [draft provisional]

Safeguards: 50.00/100 (4/8 weight)
Exposure: unassessed
Combined: unavailable; both components required
Inventory denominator: 14 entities; size factor 1/1; cap 25 points per entity.
Review groups: 0; assessment coverage warnings: 8.
Global coverage warnings remain relevant; no practice-wide completeness is established.
Scores use primary project assignments and independently capped practice views.
A missing component is not replaced or reweighted.

5. Asset management [draft provisional]

Safeguards: 100.00/100 (1/1 weight)
Exposure: unassessed
Combined: unavailable; both components required
Inventory denominator: 14 entities; size factor 1/1; cap 25 points per entity.
Review groups: 5; assessment coverage warnings: 8.
Global coverage warnings remain relevant; no practice-wide completeness is established.
Scores use primary project assignments and independently capped practice views.
A missing component is not replaced or reweighted.

6. Network management [draft provisional]

Safeguards: 100.00/100 (5/5 weight)
Exposure: unassessed
Combined: unavailable; both components required
Inventory denominator: 14 entities; size factor 1/1; cap 25 points per entity.
Review groups: 0; assessment coverage warnings: 8.
Global coverage warnings remain relevant; no practice-wide completeness is established.
Scores use primary project assignments and independently capped practice views.
A missing component is not replaced or reweighted.

7. Vulnerability management [draft provisional]

Safeguards: 50.00/100 (1/2 weight)
Exposure: unassessed
Combined: unavailable; both components required
Inventory denominator: 14 entities; size factor 1/1; cap 25 points per entity.
Review groups: 14; assessment coverage warnings: 8.
Unknown answers earning zero: Q18
Global coverage warnings remain relevant; no practice-wide completeness is established.
Scores use primary project assignments and independently capped practice views.

A missing component is not replaced or reweighted.

8. Incident response [draft provisional]

Safeguards: 57.14/100 (4/7 weight)
Exposure: unassessed
Combined: unavailable; both components required
Inventory denominator: 14 entities; size factor 1/1; cap 25 points per entity.
Review groups: 0; assessment coverage warnings: 8.
Global coverage warnings remain relevant; no practice-wide completeness is established.
Scores use primary project assignments and independently capped practice views.
A missing component is not replaced or reweighted.

9. Network-connected medical devices [draft provisional]

Safeguards: 0.00/100 (0/1 weight)
Exposure: unassessed
Combined: unavailable; both components required
Inventory denominator: 14 entities; size factor 1/1; cap 25 points per entity.
Review groups: 0; assessment coverage warnings: 8.
Unknown answers earning zero: Q23
Global coverage warnings remain relevant; no practice-wide completeness is established.
Scores use primary project assignments and independently capped practice views.
A missing component is not replaced or reweighted.

10. Security oversight and governance [draft provisional]

Safeguards: 75.00/100 (3/4 weight)
Exposure: unassessed
Combined: unavailable; both components required
Inventory denominator: 14 entities; size factor 1/1; cap 25 points per entity.
Review groups: 0; assessment coverage warnings: 8.
Global coverage warnings remain relevant; no practice-wide completeness is established.
Scores use primary project assignments and independently capped practice views.
A missing component is not replaced or reweighted.

What this score covers

The score reflects the supplied evidence and assessed scope.
Missing coverage or an informational finding does not establish safety.
- Some source or inventory coverage is unassessed.
- Some findings require verification.
- Some applied rule definitions remain drafts.

Evidence age policy

Public feeds: 8 days
Administrator observations: 30 days

Coverage requiring attention

- assessment: No service inventory is available; network services are unassessed.
- assessment: KEV cache is unavailable; missing coverage is not safety.
- assessment: EPSS cache is unavailable; missing coverage is not safety.
- software:1: No applicability records supplied; CVE coverage is unassessed.
- software:2: No applicability records supplied; CVE coverage is unassessed.
- software:3: No applicability records supplied; CVE coverage is unassessed.
- software:4: No applicability records supplied; CVE coverage is unassessed.
- software:5: No applicability records supplied; CVE coverage is unassessed.

Fix First plan

Priority is finding points divided by effort, not an estimated score increase. It does not predict a drop in real risk. Caps, shared findings and the Critical score limit affect score changes. Checklist findings add no extra score loss. Ranks compare all groups. For repeated actions, we use the highest points and highest effort. We do not add their priorities. Ties use reviewed checklist links to Essential goals. These links are partial and do not prove full Cybersecurity Performance Goals (CPG) compliance. Get an estimate for unknown costs.

Do today free
No confirmed actions assigned to this group.

This month low cost
No confirmed actions assigned to this group.

Ask your vendor
#1 - R12 - cloud:4
Priority: 3 (6 points / effort 2).
Responsible roles: Email administrator or managed service provider
Estimated cost: unknown
- Check email multifactor authentication (MFA) with the service owner. MFA adds a second proof of identity to a password. Fix confirmed gaps. Check that all accounts that need it are covered. Record any needed exceptions. Check Unknown or not applicable (NA) entries; do not treat them as enabled. Ask the IT admin which login options the service supports.

Copyable provider/lead request: For cloud:4 / Example Mail Vendor / Work Email (R12), please review the reported email MFA gap and agree protection for the affected accounts. Please provide dated evidence for reassessment and confirm the owner, cost estimate and a safe timetable before changes.
Tie evidence: confirmed KEV=False; reviewed Essential question links=Q01; confirmed patient-information scope=True.
#2 - R16 - assessment
Priority: 2 (6 points / effort 3).
Responsible roles: IT administrator and backup service provider
Estimated cost: unknown
- Check each Q10 safeguard on its own. Fix confirmed gaps in how often backups run. Check that backups are separate from daily work access. If Q11 is No, plan a controlled restore test. Record the result. Check Unknown answers; do not call them confirmed gaps. Plan tests so clinical work is not disrupted.

Copyable provider/lead request: For assessment (R16), please review backup frequency and separation individually, identifying which part failed. Please provide dated evidence for reassessment and confirm the owner, cost estimate and a safe timetable before changes.
Tie evidence: confirmed KEV=False; reviewed Essential question links=Q10; confirmed patient-information scope=False.

Policy and training
#3 - R20 - assessment
Priority: 2 (6 points / effort 3).
Responsible roles: Organizational leadership and designated security official
Estimated cost: unknown
- Check each safeguard on its own. If Q20 is No, write a plan for a security incident. List roles and contacts. If Q24a is No, name a person in charge of security and record the choice. Check Unknown answers; do not call them confirmed gaps. Keep a separate fix for each gap.

Copyable provider/lead request: For assessment (R20), please document an incident-response plan; name the person responsible for security. Please provide dated evidence for reassessment and confirm the owner, cost estimate and a safe timetable before changes.
Tie evidence: confirmed KEV=False; reviewed Essential question links=Q20; confirmed patient-information scope=False.
#4 - R17 - cloud:3
Priority: 2 (6 points / effort 3).
Responsible roles: Service owner and privacy official
Estimated cost: unknown
- Check how the service handles patient data. Ask if a Business Associate Agreement is needed. This is a contract for a vendor that handles patient data for you. Check that it exists and covers the service. Ask the owner and a qualified privacy or legal adviser. Resolve reported gaps. Check Unknown or NA entries. Do not assume the law requires this contract for every cloud service.

Copyable provider/lead request: For cloud:3 / Example Messaging Vendor / Consumer Texting (R17), please ask the responsible privacy/security lead to assess agreement applicability and obtain or review the appropriate vendor agreement. Please provide dated evidence for reassessment and confirm the owner, cost estimate and a safe timetable before changes.
Tie evidence: confirmed KEV=False; reviewed Essential question links=none; confirmed patient-information scope=True.
#5 - R17 - cloud:5
Priority: 2 (6 points / effort 3).
Responsible roles: Service owner and privacy official
Estimated cost: unknown
- Check how the service handles patient data. Ask if a Business Associate Agreement is needed. This is a contract for a vendor that handles patient data for you. Check that it exists and covers the service. Ask the owner and a qualified privacy or legal adviser. Resolve reported gaps. Check Unknown or NA entries. Do not assume the law requires this contract for every cloud service.

Copyable provider/lead request: For cloud:5 / Example Storage Vendor / Personal Cloud Drive (R17), please ask the responsible privacy/security lead to assess agreement applicability and obtain or review the appropriate vendor agreement. Please provide dated evidence for reassessment and confirm the owner, cost estimate and a safe timetable before changes.
Tie evidence: confirmed KEV=False; reviewed Essential question links=none; confirmed patient-information scope=True.
#6 - R22 - assessment
Priority: 2 (6 points / effort 3).
Responsible roles: Security official and organizational leadership
Estimated cost: unknown
- Check if there is a recent written risk analysis. It must cover the clinic's systems and risks. If it is missing, arrange a review with the right scope. Record the findings. Name an owner for each follow-up task.

Copyable provider/lead request: For assessment (R22), please ask the responsible security lead to arrange and document a scoped risk analysis. Please provide dated evidence for reassessment and confirm the owner, cost estimate and a safe timetable before changes.
Tie evidence: confirmed KEV=False; reviewed Essential question links=none; confirmed patient-information scope=False.

Verify before planning remediation

- R03 at device:SC-LT01: Verify this evidence before treating it as a confirmed gap.
- R03 at device:SC-LT02: Verify this evidence before treating it as a confirmed gap.
- R03 at device:SC-LT03: Verify this evidence before treating it as a confirmed gap.
- R03 at device:SC-LT04: Verify this evidence before treating it as a confirmed gap.
- R03 at device:SC-LT05: Verify this evidence before treating it as a confirmed gap.
- R03 at device:SC-LT06: Verify this evidence before treating it as a confirmed gap.
- R03 at device:SC-LT07: Verify this evidence before treating it as a confirmed gap.
- R03 at device:SC-PH01: Verify this evidence before treating it as a confirmed gap.
- R03 at device:SC-PH02: Verify this evidence before treating it as a confirmed gap.
- R04 at cloud:1: Verify this evidence before treating it as a confirmed gap.
- R04 at cloud:2: Verify this evidence before treating it as a confirmed gap.
- R04 at cloud:3: Verify this evidence before treating it as a confirmed gap.
- R04 at cloud:4: Verify this evidence before treating it as a confirmed gap.
- R04 at cloud:5: Verify this evidence before treating it as a confirmed gap.
- R05 at device:SC-LT03: Verify this evidence before treating it as a confirmed gap.
- R05 at device:SC-LT05: Verify this evidence before treating it as a confirmed gap.
- R10 at device:SC-LT01: Verify this evidence before treating it as a confirmed gap.
- R10 at device:SC-LT02: Verify this evidence before treating it as a confirmed gap.
- R10 at device:SC-LT03: Verify this evidence before treating it as a confirmed gap.
- R10 at device:SC-LT04: Verify this evidence before treating it as a confirmed gap.
- R10 at device:SC-LT05: Verify this evidence before treating it as a confirmed gap.
- R10 at device:SC-LT06: Verify this evidence before treating it as a confirmed gap.
- R10 at device:SC-LT07: Verify this evidence before treating it as a confirmed gap.
- R10 at device:SC-PH01: Verify this evidence before treating it as a confirmed gap.
- R10 at device:SC-PH02: Verify this evidence before treating it as a confirmed gap.
- R24 at cloud:1: Verify this evidence before treating it as a confirmed gap.
- R24 at cloud:2: Verify this evidence before treating it as a confirmed gap.

- R24 at cloud:3: Verify this evidence before treating it as a confirmed gap.
- R24 at cloud:4: Verify this evidence before treating it as a confirmed gap.
- R24 at cloud:5: Verify this evidence before treating it as a confirmed gap.

Findings from supplied evidence

1. Backup safeguards gap

Rules: R16
Entity: assessment
Severity: High
Scoring category: administrative
No additional Exposure deduction; checklist Safeguards answers are scored once.
Evidence:
R16 - confirmed
Q10: No
Q11: Yes
Recommended actions:
- Check each Q10 safeguard on its own. Fix confirmed gaps in how often backups run. Check that backups are separate from daily work access. If Q11 is No, plan a controlled restore test. Record the result. Check Unknown answers; do not call them confirmed gaps. Plan tests so clinical work is not disrupted.

Responsible roles: IT administrator and backup service provider
Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.DS-11 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Q10/Q11 combine daily backup, separation and restore testing. Project daily frequency differs from CIS 11.2; the answers do not establish CIS isolation methods or quarterly sampling.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 11.2; 11.4; 11.5 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Q10/Q11 combine daily backup, separation and restore testing. Project daily frequency differs from CIS 11.2; the answers do not establish CIS isolation methods or quarterly sampling.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 4.S.B; printed p. 21 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Q10 does not distinguish frequency from separation. Backup copies are Required; contingency testing is Addressable. Daily frequency and a six-month test interval are project benchmarks.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=24
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(7)(ii)(A); 164.308(a)(7)(ii)(D) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Q10 does not distinguish frequency from separation. Backup copies are Required; contingency testing is Addressable. Daily frequency and a six-month test interval are project benchmarks. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: HHS Healthcare CPG - Basic Incident Planning and Preparedness (Essential; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Backup/restore checks support recovery; they do not demonstrate complete incident readiness. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html
Source-checked project mapping: HICP 2023 - Volume 2: 4.M.D; printed pp. 50-52 (partial; recovery supplement)
Mapping scope: Partial project mapping; source checked October 30, 2026. Supplement for the restore-testing branch from medium/large-organization guidance; not a complete small-clinic recovery assessment or a mandated test interval.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol2-508.pdf#page=57

2. Incident planning or security responsibility gap

Rules: R20
Entity: assessment
Severity: High
Scoring category: administrative
No additional Exposure deduction; checklist Safeguards answers are scored once.
Evidence:
R20 - confirmed
Q20: No
Q24a: No
Recommended actions:
- Check each safeguard on its own. If Q20 is No, write a plan for a security incident. List roles and contacts. If Q24a is No, name a person in charge of security and record the choice. Check Unknown answers; do not call them confirmed gaps. Keep a separate fix for each gap.
Responsible roles: Organizational leadership and designated security official
Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - ID.IM-04; GV.RR-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Q20 and Q24a distinguish an incident plan from security responsibility. General security ownership is broader than the CIS incident-handling role; neither answer tests execution.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=22
Source-checked project mapping: CIS Controls v8.1 - 17.1; 17.4 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Q20 and Q24a distinguish an incident plan from security responsibility. General security ownership is broader than the CIS incident-handling role; neither answer tests execution.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 8.S.A; 10.S.A; printed p. 27 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Incident planning and security responsibility are separate branches. A combined finding does not mean both failed or that response procedures were exercised.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=30
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(6)(i); 164.308(a)(2) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Incident planning and security responsibility are separate branches. A combined finding does not mean both failed or that response procedures were exercised. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: HHS Healthcare CPG - Basic Incident Planning and Preparedness (Essential; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Incident-plan branch only; naming a responsible person alone does not demonstrate preparedness. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

3. Documented risk analysis gap

Rules: R22
Entity: assessment
Severity: High
Scoring category: administrative
No additional Exposure deduction; checklist Safeguards answers are scored once.
Evidence:
R22 - confirmed
Q24b: No
Recommended actions:
- Check if there is a recent written risk analysis. It must cover the clinic's systems and risks. If it is missing, arrange a review with the right scope. Record the findings. Name an owner for each follow-up task.
Responsible roles: Security official and organizational leadership
Estimated effort: Vendor involvement, budget, or several weeks

Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - ID.RA-04; ID.RA-05 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Q24b reports documented risk analysis. It does not verify assessment quality, complete threat coverage, likelihood methods or legal sufficiency.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=24
Source-checked project mapping: HICP 2023 - Volume 1: 10.S.B; printed p. 33 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Reported absence of documented risk analysis prompts follow-up; a Yes answer would not establish a thorough or sufficient legal risk analysis.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=36
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(A) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Reported absence of documented risk analysis prompts follow-up; a Yes answer would not establish a thorough or sufficient legal risk analysis. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308

4. Cloud service agreement requires attention

Rules: R17
Entity: cloud:3
Severity: High
Scoring category: administrative
No additional Exposure deduction; checklist Safeguards answers are scored once.
Evidence:
- R17 - confirmed
  - Asset id: CLOUD
  - Vendor: Example Messaging Vendor
  - Product: Consumer Texting
  - Deployment: cloud
  - Touches phi: Y
  - Baa signed: N

Recommended actions:
- Check how the service handles patient data. Ask if a Business Associate Agreement is needed. This is a contract for a vendor that handles patient data for you. Check that it exists and covers the service. Ask the owner and a qualified privacy or legal adviser. Resolve reported gaps. Check Unknown or NA entries. Do not assume the law requires this contract for every cloud service.

Responsible roles: Service owner and privacy official
Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - GV.SC-05 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. A reported missing BAA is a narrow agreement gap. These references concern security agreements generally; they do not establish BAA applicability, contractual sufficiency or legal compliance.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=23
Source-checked project mapping: CIS Controls v8.1 - 15.4 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. A reported missing BAA is a narrow agreement gap. These references concern security agreements generally; they do not establish BAA applicability, contractual sufficiency or legal compliance.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 4.S.B; printed p. 21 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Agreement presence does not establish BAA applicability, contract sufficiency or vendor implementation; evaluate the vendor relationship first.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=24
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.314(a)(1); 164.314(a)(2)(i) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Agreement presence does not establish BAA applicability, contract sufficiency or vendor implementation; evaluate the vendor relationship first. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.314
Source-checked project mapping: HHS Healthcare CPG - Vendor/Supplier Cybersecurity Requirements (Essential; partial)

Mapping scope: Partial project mapping; source checked October 30, 2026. Agreement presence is narrower than verified supplier requirements and implementation. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

5. Email multifactor authentication gap

Rules: R12
Entity: cloud:4
Severity: High
Scoring category: administrative
No additional Exposure deduction; checklist Safeguards answers are scored once.
Evidence:
R12 - confirmed
Asset id: CLOUD
Vendor: Example Mail Vendor
Product: Work Email
Purpose: email
Deployment: cloud
Mfa enabled: N
Recommended actions:
- Check email multifactor authentication (MFA) with the service owner. MFA adds a second proof of identity to a password. Fix confirmed gaps. Check that all accounts that need it are covered. Record any needed exceptions. Check Unknown or not applicable (NA) entries; do not treat them as enabled. Ask the IT admin which login options the service supports.

Responsible roles: Email administrator or managed service provider
Estimated effort: A day of work or a small cost
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.AA-03 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Email MFA coverage is a project check. CIS 6.3 applies conditionally to externally exposed applications where supported; all account configurations are not verified.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=24
Source-checked project mapping: CIS Controls v8.1 - 6.3 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Email MFA coverage is a project check. CIS 6.3 applies conditionally to externally exposed applications where supported; all account configurations are not verified.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 1.S.A; printed p. 10 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Email MFA evidence covers supplied accounts; phishing resistance and all authentication procedures are not verified.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=13
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.312(d) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Email MFA evidence covers supplied accounts; phishing resistance and all authentication procedures are not verified. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.312
Source-checked project mapping: HHS Healthcare CPG - Email Security (Essential; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Email MFA is one component; filtering, forwarding and other email safeguards are outside this rule. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

6. Cloud service agreement requires attention

Rules: R17
Entity: cloud:5
Severity: High
Scoring category: administrative
No additional Exposure deduction; checklist Safeguards answers are scored once.
Evidence:
R17 - confirmed

Asset id: CLOUD
Vendor: Example Storage Vendor
Product: Personal Cloud Drive
Deployment: cloud
Touches phi: Y
Baa signed: N

Recommended actions:

- Check how the service handles patient data. Ask if a Business Associate Agreement is needed. This is a contract for a vendor that handles patient data for you. Check that it exists and covers the service. Ask the owner and a qualified privacy or legal adviser. Resolve reported gaps. Check Unknown or NA entries. Do not assume the law requires this contract for every cloud service.

Responsible roles: Service owner and privacy official
Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - GV.SC-05 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. A reported missing BAA is a narrow agreement gap. These references concern security agreements generally; they do not establish BAA applicability, contractual sufficiency or legal compliance.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=23
Source-checked project mapping: CIS Controls v8.1 - 15.4 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. A reported missing BAA is a narrow agreement gap. These references concern security agreements generally; they do not establish BAA applicability, contractual sufficiency or legal compliance.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 4.S.B; printed p. 21 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Agreement presence does not establish BAA applicability, contract sufficiency or vendor implementation; evaluate the vendor relationship first.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=24
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.314(a)(1); 164.314(a)(2)(i) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Agreement presence does not establish BAA applicability, contract sufficiency or vendor implementation; evaluate the vendor relationship first. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.314
Source-checked project mapping: HHS Healthcare CPG - Vendor/Supplier Cybersecurity Requirements (Essential; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Agreement presence is narrower than verified supplier requirements and implementation. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

Items requiring verification

1. Application support requires attention

Rules: R04
Entity: cloud:1
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:

R04 - needs review
Asset id: CLOUD
Vendor: Example EHR Vendor
Product: Counseling EHR
Version: Unknown
Deployment: cloud
Support status: unknown
Support basis: Application support evidence is missing.
Extended support: unknown

Recommended actions:

- Check the app release and the vendor's support terms. If support has ended, plan an upgrade or replacement. A vendor-approved workaround may also be an option. Plan changes with app owners and clinical users. Ask the cloud vendor for proof when you cannot check its release or support terms.

Responsible roles: Application owner and software vendor
Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.PS-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Application support evidence covers one supplied release. Inventory authorization, documented exceptions and ongoing review are outside this finding.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 2.2 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Application support evidence covers one supplied release. Inventory authorization, documented exceptions and ongoing review are outside this finding.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 14 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Application support is assessed per supplied release; compensating controls and risk acceptance are not audited.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=17
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(B) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Application support is assessed per supplied release; compensating controls and risk acceptance are not audited. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308

2. Software version requires verification

Rules: R24
Entity: cloud:1
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:

- R24 - needs review
  - Asset id: CLOUD
  - Vendor: Example EHR Vendor
  - Product: Counseling EHR
  - Version: Unknown
  - Deployment: cloud
  - Touches phi: Y

Recommended actions:

- Get the installed version or the cloud service's release from a reliable source. If it is unclear, check whether the software has access to patient data. Record version details the vendor has not yet supplied. Then check again which flaws apply. Do not invent a version or treat missing data as safe.

Responsible roles: IT administrator or application vendor
Estimated effort: Under an hour and free
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - ID.AM-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unknown versions require inventory follow-up. Versions are identifiers here, not proof of vulnerability; the rule does not audit every inventory field or its review cadence.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=23
Source-checked project mapping: CIS Controls v8.1 - 2.1 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unknown versions require inventory follow-up. Versions are identifiers here, not proof of vulnerability; the rule does not audit every inventory field or its review cadence.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 5.S.A; printed p. 22 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unknown software versions are inventory uncertainty supporting risk-analysis follow-up, not confirmed vulnerabilities or a complete risk analysis.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=25

Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(A) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unknown software versions are inventory uncertainty supporting risk-analysis follow-up, not confirmed vulnerabilities or a complete risk analysis. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: HHS Healthcare CPG - Asset Inventory (Enhanced; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Version completeness for selected software only; no comprehensive asset discovery or inventory cadence is established. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

3. Application support requires attention

Rules: R04
Entity: cloud:2
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R04 - needs review
Asset id: CLOUD
Vendor: Example Telehealth Vendor
Product: Video Care
Version: Unknown
Deployment: cloud
Support status: unknown
Support basis: Application support evidence is missing.
Extended support: unknown
Recommended actions:
- Check the app release and the vendor's support terms. If support has ended, plan an upgrade or replacement. A vendor-approved workaround may also be an option. Plan changes with app owners and clinical users. Ask the cloud vendor for proof when you cannot check its release or support terms.
Responsible roles: Application owner and software vendor
Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.PS-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Application support evidence covers one supplied release. Inventory authorization, documented exceptions and ongoing review are outside this finding.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 2.2 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Application support evidence covers one supplied release. Inventory authorization, documented exceptions and ongoing review are outside this finding.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 14 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Application support is assessed per supplied release; compensating controls and risk acceptance are not audited.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=17
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(B) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Application support is assessed per supplied release; compensating controls and risk acceptance are not audited. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308

4. Software version requires verification

Rules: R24
Entity: cloud:2
Severity: Info
Scoring category: technical

No confirmed-risk Exposure deduction.
Evidence:
R24 - needs review
Asset id: CLOUD
Vendor: Example Telehealth Vendor
Product: Video Care
Version: Unknown
Deployment: cloud
Touches phi: Y
Recommended actions:
- Get the installed version or the cloud service's release from a reliable source. If it is unclear, check whether the software has access to patient data. Record version details the vendor has not yet supplied. Then check again which flaws apply. Do not invent a version or treat missing data as safe.
Responsible roles: IT administrator or application vendor
Estimated effort: Under an hour and free
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - ID.AM-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unknown versions require inventory follow-up. Versions are identifiers here, not proof of vulnerability; the rule does not audit every inventory field or its review cadence.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=23
Source-checked project mapping: CIS Controls v8.1 - 2.1 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unknown versions require inventory follow-up. Versions are identifiers here, not proof of vulnerability; the rule does not audit every inventory field or its review cadence.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 5.S.A; printed p. 22 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unknown software versions are inventory uncertainty supporting risk-analysis follow-up, not confirmed vulnerabilities or a complete risk analysis.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=25
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(A) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unknown software versions are inventory uncertainty supporting risk-analysis follow-up, not confirmed vulnerabilities or a complete risk analysis. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: HHS Healthcare CPG - Asset Inventory (Enhanced; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Version completeness for selected software only; no comprehensive asset discovery or inventory cadence is established. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

5. Application support requires attention

Rules: R04
Entity: cloud:3
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R04 - needs review
Asset id: CLOUD
Vendor: Example Messaging Vendor
Product: Consumer Texting
Version: Unknown
Deployment: cloud
Support status: unknown
Support basis: Application support evidence is missing.
Extended support: unknown
Recommended actions:
- Check the app release and the vendor's support terms. If support has ended, plan an upgrade or replacement. A

vendor-approved workaround may also be an option. Plan changes with app owners and clinical users. Ask the cloud vendor for proof when you cannot check its release or support terms.
Responsible roles: Application owner and software vendor
Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.PS-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Application support evidence covers one supplied release. Inventory authorization, documented exceptions and ongoing review are outside this finding.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 2.2 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Application support evidence covers one supplied release. Inventory authorization, documented exceptions and ongoing review are outside this finding.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 14 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Application support is assessed per supplied release; compensating controls and risk acceptance are not audited.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=17
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(B) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Application support is assessed per supplied release; compensating controls and risk acceptance are not audited. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308

6. Software version requires verification

Rules: R24
Entity: cloud:3
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
- R24 - needs review
  - Asset id: CLOUD
  - Vendor: Example Messaging Vendor
  - Product: Consumer Texting
  - Version: Unknown
  - Deployment: cloud
  - Touches phi: Y

Recommended actions:
- Get the installed version or the cloud service's release from a reliable source. If it is unclear, check whether the software has access to patient data. Record version details the vendor has not yet supplied. Then check again which flaws apply. Do not invent a version or treat missing data as safe.

Responsible roles: IT administrator or application vendor
Estimated effort: Under an hour and free
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - ID.AM-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unknown versions require inventory follow-up. Versions are identifiers here, not proof of vulnerability; the rule does not audit every inventory field or its review cadence.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=23
Source-checked project mapping: CIS Controls v8.1 - 2.1 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unknown versions require inventory follow-up. Versions are identifiers here, not proof of vulnerability; the rule does not audit every inventory field or its review cadence.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 5.S.A; printed p. 22 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unknown software versions are inventory uncertainty supporting risk-analysis follow-up, not confirmed vulnerabilities or a complete risk analysis.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=25
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(A) (partial;

applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unknown software versions are inventory uncertainty supporting risk-analysis follow-up, not confirmed vulnerabilities or a complete risk analysis. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: HHS Healthcare CPG - Asset Inventory (Enhanced; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Version completeness for selected software only; no comprehensive asset discovery or inventory cadence is established. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

7. Application support requires attention

Rules: R04
Entity: cloud:4
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R04 - needs review
Asset id: CLOUD
Vendor: Example Mail Vendor
Product: Work Email
Version: Unknown
Deployment: cloud
Support status: unknown
Support basis: Application support evidence is missing.
Extended support: unknown
Recommended actions:
- Check the app release and the vendor's support terms. If support has ended, plan an upgrade or replacement. A vendor-approved workaround may also be an option. Plan changes with app owners and clinical users. Ask the cloud vendor for proof when you cannot check its release or support terms.
Responsible roles: Application owner and software vendor
Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.PS-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Application support evidence covers one supplied release. Inventory authorization, documented exceptions and ongoing review are outside this finding.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 2.2 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Application support evidence covers one supplied release. Inventory authorization, documented exceptions and ongoing review are outside this finding.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 14 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Application support is assessed per supplied release; compensating controls and risk acceptance are not audited.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=17
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(B) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Application support is assessed per supplied release; compensating controls and risk acceptance are not audited. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308

8. Software version requires verification

Rules: R24
Entity: cloud:4
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.

Evidence:
R24 - needs review
Asset id: CLOUD
Vendor: Example Mail Vendor
Product: Work Email
Version: Unknown
Deployment: cloud
Touches phi: Y
Recommended actions:
- Get the installed version or the cloud service's release from a reliable source. If it is unclear, check whether the software has access to patient data. Record version details the vendor has not yet supplied. Then check again which flaws apply. Do not invent a version or treat missing data as safe.
Responsible roles: IT administrator or application vendor
Estimated effort: Under an hour and free
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - ID.AM-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unknown versions require inventory follow-up. Versions are identifiers here, not proof of vulnerability; the rule does not audit every inventory field or its review cadence.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=23
Source-checked project mapping: CIS Controls v8.1 - 2.1 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unknown versions require inventory follow-up. Versions are identifiers here, not proof of vulnerability; the rule does not audit every inventory field or its review cadence.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 5.S.A; printed p. 22 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unknown software versions are inventory uncertainty supporting risk-analysis follow-up, not confirmed vulnerabilities or a complete risk analysis.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=25
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(A) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unknown software versions are inventory uncertainty supporting risk-analysis follow-up, not confirmed vulnerabilities or a complete risk analysis. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: HHS Healthcare CPG - Asset Inventory (Enhanced; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Version completeness for selected software only; no comprehensive asset discovery or inventory cadence is established. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

9. Application support requires attention

Rules: R04
Entity: cloud:5
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R04 - needs review
Asset id: CLOUD
Vendor: Example Storage Vendor
Product: Personal Cloud Drive
Version: Unknown
Deployment: cloud
Support status: unknown
Support basis: Application support evidence is missing.
Extended support: unknown
Recommended actions:
- Check the app release and the vendor's support terms. If support has ended, plan an upgrade or replacement. A vendor-approved workaround may also be an option. Plan changes with app owners and clinical users. Ask the

cloud vendor for proof when you cannot check its release or support terms.
Responsible roles: Application owner and software vendor
Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.PS-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Application support evidence covers one supplied release. Inventory authorization, documented exceptions and ongoing review are outside this finding.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 2.2 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Application support evidence covers one supplied release. Inventory authorization, documented exceptions and ongoing review are outside this finding.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 14 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Application support is assessed per supplied release; compensating controls and risk acceptance are not audited.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=17
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(B) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Application support is assessed per supplied release; compensating controls and risk acceptance are not audited. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308

10. Software version requires verification

Rules: R24
Entity: cloud:5
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R24 - needs review
Asset id: CLOUD
Vendor: Example Storage Vendor
Product: Personal Cloud Drive
Version: Unknown
Deployment: cloud
Touches phi: Y
Recommended actions:
- Get the installed version or the cloud service's release from a reliable source. If it is unclear, check whether the software has access to patient data. Record version details the vendor has not yet supplied. Then check again which flaws apply. Do not invent a version or treat missing data as safe.
Responsible roles: IT administrator or application vendor
Estimated effort: Under an hour and free
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - ID.AM-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unknown versions require inventory follow-up. Versions are identifiers here, not proof of vulnerability; the rule does not audit every inventory field or its review cadence.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=23
Source-checked project mapping: CIS Controls v8.1 - 2.1 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unknown versions require inventory follow-up. Versions are identifiers here, not proof of vulnerability; the rule does not audit every inventory field or its review cadence.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 5.S.A; printed p. 22 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unknown software versions are inventory uncertainty supporting risk-analysis follow-up, not confirmed vulnerabilities or a complete risk analysis.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=25
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(A) (partial; applicability-dependent)

Mapping scope: Partial project mapping; source checked October 30, 2026. Unknown software versions are inventory uncertainty supporting risk-analysis follow-up, not confirmed vulnerabilities or a complete risk analysis. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: HHS Healthcare CPG - Asset Inventory (Enhanced; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Version completeness for selected software only; no comprehensive asset discovery or inventory cadence is established. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

11. Default administrator password requires attention

Rules: R10
Entity: device:SC-LT01
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R10 - needs review
Asset id: SC-LT01
Applicability: Unknown
Default password changed: Unknown
Evidence basis: Default-password applicability and status are unverified.
Recommended actions:
- Check if this device still uses a default admin login. If the default password is unchanged, plan a supported change with the IT admin or vendor. Store the new login details safely. Keep needed work running. Never put passwords in the input files, evidence or logs.
Responsible roles: Device administrator or responsible vendor
Estimated effort: A day of work or a small cost
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.AA-01 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=24
Source-checked project mapping: CIS Controls v8.1 - 4.7 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 7.S.A; printed p. 26 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=29
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(5)(ii)(D) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: HHS Healthcare CPG - Configuration Management (Enhanced; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. One default-credential setting only; not a unique-credentials or complete baseline assessment. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

12. Operating system support requires attention

Rules: R03
Entity: device:SC-LT01
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.

Evidence:
R03 - needs review
Asset id: SC-LT01
Os name: macOS
Os version: 15
Support status: unknown
Support basis: Lifecycle evidence is missing.
Extended support: unknown
Recommended actions:
- Check the system release and its support terms. Check any paid or extended security updates too. If support has ended, plan an upgrade or a new system. A vendor-approved workaround may also be an option. Plan medical-device changes with the vendor. If the evidence is unclear, check it. Do not yet claim that the system has support or that support has ended.
Responsible roles: IT administrator and system vendor
Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.PS-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 2.2 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 14 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=17
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(B) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308

13. Default administrator password requires attention

Rules: R10
Entity: device:SC-LT02
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R10 - needs review
Asset id: SC-LT02
Applicability: Unknown
Default password changed: Unknown
Evidence basis: Default-password applicability and status are unverified.
Recommended actions:
- Check if this device still uses a default admin login. If the default password is unchanged, plan a supported change with the IT admin or vendor. Store the new login details safely. Keep needed work running. Never put passwords in the input files, evidence or logs.
Responsible roles: Device administrator or responsible vendor
Estimated effort: A day of work or a small cost
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.AA-01 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=24

Source-checked project mapping: CIS Controls v8.1 - 4.7 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 7.S.A; printed p. 26 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=29
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(5)(ii)(D) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: HHS Healthcare CPG - Configuration Management (Enhanced; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. One default-credential setting only; not a unique-credentials or complete baseline assessment. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

14. Operating system support requires attention

Rules: R03
Entity: device:SC-LT02
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R03 - needs review
Asset id: SC-LT02
Os name: macOS
Os version: 15
Support status: unknown
Support basis: Lifecycle evidence is missing.
Extended support: unknown
Recommended actions:
- Check the system release and its support terms. Check any paid or extended security updates too. If support has ended, plan an upgrade or a new system. A vendor-approved workaround may also be an option. Plan medical-device changes with the vendor. If the evidence is unclear, check it. Do not yet claim that the system has support or that support has ended.
Responsible roles: IT administrator and system vendor
Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.PS-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 2.2 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 14 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=17
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(B) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban. Supporting relationship only; not a compliance

finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308

15. Portable-device encryption gap

Rules: R05
Entity: device:SC-LT03
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R05 - needs review
Asset id: SC-LT03
Portable: Y
Encrypted: Unknown
Recommended actions:
- Check whether device encryption is on. Encryption scrambles stored data so a key is needed to read it. If it is off, ask the IT admin to turn on a supported option. Store recovery keys safely and check the result. Plan changes to managed or medical devices with their vendor.
Responsible roles: IT administrator or managed service provider
Estimated effort: A day of work or a small cost
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.DS-01 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. This rule covers portable assets and supplied encryption status only. It does not inventory every sensitive-data location or verify cryptographic configuration.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 3.6 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. This rule covers portable assets and supplied encryption status only. It does not inventory every sensitive-data location or verify cryptographic configuration.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 14 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Portable-device encryption status is reported, not cryptographic effectiveness. Encryption/decryption is Addressable; this finding is not a legal determination.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=17
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.312(a)(2)(iv) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Portable-device encryption status is reported, not cryptographic effectiveness. Encryption/decryption is Addressable; this finding is not a legal determination. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.312

16. Default administrator password requires attention

Rules: R10
Entity: device:SC-LT03
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R10 - needs review
Asset id: SC-LT03
Applicability: Unknown
Default password changed: Unknown
Evidence basis: Default-password applicability and status are unverified.
Recommended actions:
- Check if this device still uses a default admin login. If the default password is unchanged, plan a supported change with the IT admin or vendor. Store the new login details safely. Keep needed work running. Never put passwords in the input files, evidence or logs.
Responsible roles: Device administrator or responsible vendor

Estimated effort: A day of work or a small cost
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.AA-01 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=24
Source-checked project mapping: CIS Controls v8.1 - 4.7 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 7.S.A; printed p. 26 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=29
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(5)(ii)(D) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: HHS Healthcare CPG - Configuration Management (Enhanced; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. One default-credential setting only; not a unique-credentials or complete baseline assessment. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

17. Operating system support requires attention

Rules: R03
Entity: device:SC-LT03
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R03 - needs review
Asset id: SC-LT03
Os name: macOS
Os version: 15
Support status: unknown
Support basis: Lifecycle evidence is missing.
Extended support: unknown
Recommended actions:
- Check the system release and its support terms. Check any paid or extended security updates too. If support has ended, plan an upgrade or a new system. A vendor-approved workaround may also be an option. Plan medical-device changes with the vendor. If the evidence is unclear, check it. Do not yet claim that the system has support or that support has ended.
Responsible roles: IT administrator and system vendor
Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.PS-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 2.2 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 14 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not

a full risk-management assessment or a specific legal product ban.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=17
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(B) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308

18. Default administrator password requires attention

Rules: R10
Entity: device:SC-LT04
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R10 - needs review
Asset id: SC-LT04
Applicability: Unknown
Default password changed: Unknown
Evidence basis: Default-password applicability and status are unverified.
Recommended actions:
- Check if this device still uses a default admin login. If the default password is unchanged, plan a supported change with the IT admin or vendor. Store the new login details safely. Keep needed work running. Never put passwords in the input files, evidence or logs.
Responsible roles: Device administrator or responsible vendor
Estimated effort: A day of work or a small cost
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.AA-01 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=24
Source-checked project mapping: CIS Controls v8.1 - 4.7 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 7.S.A; printed p. 26 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=29
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(5)(ii)(D) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: HHS Healthcare CPG - Configuration Management (Enhanced; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. One default-credential setting only; not a unique-credentials or complete baseline assessment. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

19. Operating system support requires attention

Rules: R03
Entity: device:SC-LT04
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:

R03 - needs review
Asset id: SC-LT04
Os name: macOS
Os version: 15
Support status: unknown
Support basis: Lifecycle evidence is missing.
Extended support: unknown
Recommended actions:
- Check the system release and its support terms. Check any paid or extended security updates too. If support has ended, plan an upgrade or a new system. A vendor-approved workaround may also be an option. Plan medical-device changes with the vendor. If the evidence is unclear, check it. Do not yet claim that the system has support or that support has ended.
Responsible roles: IT administrator and system vendor
Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.PS-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 2.2 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 14 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=17
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(B) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308

20. Portable-device encryption gap

Rules: R05
Entity: device:SC-LT05
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R05 - needs review
Asset id: SC-LT05
Portable: Y
Encrypted: Unknown
Recommended actions:
- Check whether device encryption is on. Encryption scrambles stored data so a key is needed to read it. If it is off, ask the IT admin to turn on a supported option. Store recovery keys safely and check the result. Plan changes to managed or medical devices with their vendor.
Responsible roles: IT administrator or managed service provider
Estimated effort: A day of work or a small cost
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.DS-01 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. This rule covers portable assets and supplied encryption status only. It does not inventory every sensitive-data location or verify cryptographic configuration.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 3.6 (partial; conditional where stated)

Mapping scope: Partial project mapping; source checked October 29, 2026. This rule covers portable assets and supplied encryption status only. It does not inventory every sensitive-data location or verify cryptographic configuration.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 14 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Portable-device encryption status is reported, not cryptographic effectiveness. Encryption/decryption is Addressable; this finding is not a legal determination.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=17
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.312(a)(2)(iv) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Portable-device encryption status is reported, not cryptographic effectiveness. Encryption/decryption is Addressable; this finding is not a legal determination. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.312

21. Default administrator password requires attention

Rules: R10
Entity: device:SC-LT05
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R10 - needs review
Asset id: SC-LT05
Applicability: Unknown
Default password changed: Unknown
Evidence basis: Default-password applicability and status are unverified.
Recommended actions:
- Check if this device still uses a default admin login. If the default password is unchanged, plan a supported change with the IT admin or vendor. Store the new login details safely. Keep needed work running. Never put passwords in the input files, evidence or logs.
Responsible roles: Device administrator or responsible vendor
Estimated effort: A day of work or a small cost
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.AA-01 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=24
Source-checked project mapping: CIS Controls v8.1 - 4.7 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 7.S.A; printed p. 26 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=29
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(5)(ii)(D) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: HHS Healthcare CPG - Configuration Management (Enhanced; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. One default-credential setting only; not a unique-credentials or complete baseline assessment. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

22. Operating system support requires attention

Rules: R03
Entity: device:SC-LT05
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R03 - needs review
Asset id: SC-LT05
Os name: Windows
Os version: 11 24H2
Support status: unknown
Support basis: Lifecycle evidence is missing.
Extended support: unknown
Recommended actions:
- Check the system release and its support terms. Check any paid or extended security updates too. If support has ended, plan an upgrade or a new system. A vendor-approved workaround may also be an option. Plan medical-device changes with the vendor. If the evidence is unclear, check it. Do not yet claim that the system has support or that support has ended.
Responsible roles: IT administrator and system vendor
Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.PS-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 2.2 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 14 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=17
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(B) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308

23. Default administrator password requires attention

Rules: R10
Entity: device:SC-LT06
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R10 - needs review
Asset id: SC-LT06
Applicability: Unknown
Default password changed: Unknown
Evidence basis: Default-password applicability and status are unverified.
Recommended actions:
- Check if this device still uses a default admin login. If the default password is unchanged, plan a supported change with the IT admin or vendor. Store the new login details safely. Keep needed work running. Never put passwords in the input files, evidence or logs.

Responsible roles: Device administrator or responsible vendor
Estimated effort: A day of work or a small cost
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.AA-01 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=24
Source-checked project mapping: CIS Controls v8.1 - 4.7 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 7.S.A; printed p. 26 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=29
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(5)(ii)(D) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: HHS Healthcare CPG - Configuration Management (Enhanced; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. One default-credential setting only; not a unique-credentials or complete baseline assessment. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

24. Operating system support requires attention

Rules: R03
Entity: device:SC-LT06
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R03 - needs review
Asset id: SC-LT06
Os name: Windows
Os version: 11 24H2
Support status: unknown
Support basis: Lifecycle evidence is missing.
Extended support: unknown
Recommended actions:
- Check the system release and its support terms. Check any paid or extended security updates too. If support has ended, plan an upgrade or a new system. A vendor-approved workaround may also be an option. Plan medical-device changes with the vendor. If the evidence is unclear, check it. Do not yet claim that the system has support or that support has ended.
Responsible roles: IT administrator and system vendor
Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.PS-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 2.2 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 14 (partial)

Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=17
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(B) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308

25. Default administrator password requires attention

Rules: R10
Entity: device:SC-LT07
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R10 - needs review
Asset id: SC-LT07
Applicability: Unknown
Default password changed: Unknown
Evidence basis: Default-password applicability and status are unverified.
Recommended actions:
- Check if this device still uses a default admin login. If the default password is unchanged, plan a supported change with the IT admin or vendor. Store the new login details safely. Keep needed work running. Never put passwords in the input files, evidence or logs.
Responsible roles: Device administrator or responsible vendor
Estimated effort: A day of work or a small cost
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.AA-01 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=24
Source-checked project mapping: CIS Controls v8.1 - 4.7 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 7.S.A; printed p. 26 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=29
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(5)(ii)(D) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: HHS Healthcare CPG - Configuration Management (Enhanced; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. One default-credential setting only; not a unique-credentials or complete baseline assessment. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

26. Operating system support requires attention

Rules: R03
Entity: device:SC-LT07
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.

Evidence:
R03 - needs review
Asset id: SC-LT07
Os name: Windows
Os version: 11 24H2
Support status: unknown
Support basis: Lifecycle evidence is missing.
Extended support: unknown
Recommended actions:
- Check the system release and its support terms. Check any paid or extended security updates too. If support has ended, plan an upgrade or a new system. A vendor-approved workaround may also be an option. Plan medical-device changes with the vendor. If the evidence is unclear, check it. Do not yet claim that the system has support or that support has ended.
Responsible roles: IT administrator and system vendor
Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.PS-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 2.2 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 14 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=17
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(B) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308

27. Default administrator password requires attention

Rules: R10
Entity: device:SC-PH01
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R10 - needs review
Asset id: SC-PH01
Applicability: Unknown
Default password changed: Unknown
Evidence basis: Default-password applicability and status are unverified.
Recommended actions:
- Check if this device still uses a default admin login. If the default password is unchanged, plan a supported change with the IT admin or vendor. Store the new login details safely. Keep needed work running. Never put passwords in the input files, evidence or logs.
Responsible roles: Device administrator or responsible vendor
Estimated effort: A day of work or a small cost
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.AA-01 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=24

Source-checked project mapping: CIS Controls v8.1 - 4.7 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 7.S.A; printed p. 26 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=29
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(5)(ii)(D) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: HHS Healthcare CPG - Configuration Management (Enhanced; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. One default-credential setting only; not a unique-credentials or complete baseline assessment. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

28. Operating system support requires attention

Rules: R03
Entity: device:SC-PH01
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R03 - needs review
Asset id: SC-PH01
Os name: iOS
Os version: Unknown
Support status: unknown
Support basis: Lifecycle evidence is missing.
Extended support: unknown
Recommended actions:
- Check the system release and its support terms. Check any paid or extended security updates too. If support has ended, plan an upgrade or a new system. A vendor-approved workaround may also be an option. Plan medical-device changes with the vendor. If the evidence is unclear, check it. Do not yet claim that the system has support or that support has ended.
Responsible roles: IT administrator and system vendor
Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.PS-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 2.2 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 14 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=17
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(B) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban. Supporting relationship only; not a compliance

finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308

29. Default administrator password requires attention

Rules: R10
Entity: device:SC-PH02
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R10 - needs review
Asset id: SC-PH02
Applicability: Unknown
Default password changed: Unknown
Evidence basis: Default-password applicability and status are unverified.
Recommended actions:
- Check if this device still uses a default admin login. If the default password is unchanged, plan a supported change with the IT admin or vendor. Store the new login details safely. Keep needed work running. Never put passwords in the input files, evidence or logs.
Responsible roles: Device administrator or responsible vendor
Estimated effort: A day of work or a small cost
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.AA-01 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=24
Source-checked project mapping: CIS Controls v8.1 - 4.7 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. Unchanged default-password evidence covers one credential condition. It does not independently audit all default accounts or their necessity.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 7.S.A; printed p. 26 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=29
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(5)(ii)(D) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. Unchanged-default-password evidence covers one credential condition. Password management is Addressable; no full credential audit is performed. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308
Source-checked project mapping: HHS Healthcare CPG - Configuration Management (Enhanced; partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. One default-credential setting only; not a unique-credentials or complete baseline assessment. Voluntary goal; no full attainment or legal compliance inferred.
Source: https://hhscyber.hhs.gov/cybersecurity-performance-goals.html

30. Operating system support requires attention

Rules: R03
Entity: device:SC-PH02
Severity: Info
Scoring category: technical
No confirmed-risk Exposure deduction.
Evidence:
R03 - needs review
Asset id: SC-PH02
Os name: Android
Os version: Unknown
Support status: unknown
Support basis: Lifecycle evidence is missing.

Extended support: unknown
Recommended actions:
- Check the system release and its support terms. Check any paid or extended security updates too. If support has ended, plan an upgrade or a new system. A vendor-approved workaround may also be an option. Plan medical-device changes with the vendor. If the evidence is unclear, check it. Do not yet claim that the system has support or that support has ended.

Responsible roles: IT administrator and system vendor
Estimated effort: Vendor involvement, budget, or several weeks
Estimated cost: unknown
Source-checked project mapping: NIST CSF 2.0 - PR.PS-02 (partial)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://nvlpubs.nist.gov/nistpubs/CSWP/NIST.CSWP.29.pdf#page=25
Source-checked project mapping: CIS Controls v8.1 - 2.2 (partial; conditional where stated)
Mapping scope: Partial project mapping; source checked October 29, 2026. The rule evaluates a supplied OS release and support coverage. It does not assess every software exception, compensating control or residual-risk acceptance.
Source: https://www.cisecurity.org/controls/CIS-controls-navigator
Source-checked project mapping: HICP 2023 - Volume 1: 2.S.A; printed p. 14 (partial)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban.
Source: https://hhscyber.hhs.gov/Documents/HICP/tech-vol1-508.pdf#page=17
Source-checked project mapping: HIPAA Security Rule - 45 CFR 164.308(a)(1)(ii)(B) (partial; applicability-dependent)
Mapping scope: Partial project mapping; source checked October 30, 2026. OS support status is one risk input, not a full risk-management assessment or a specific legal product ban. Supporting relationship only; not a compliance finding.
Source: https://www.ecfr.gov/current/title-45/subtitle-A/subchapter-C/part-164/subpart-C/section-164.308